

Group 4

Lab 5&6: Authentication System and Role-Based Access
Control

Submitted to: Engr. Jhomark Alber

Members:

Ebreo, Steven Eugenio

Gallardo, John Lorenz

Hernandez, Kert Winard

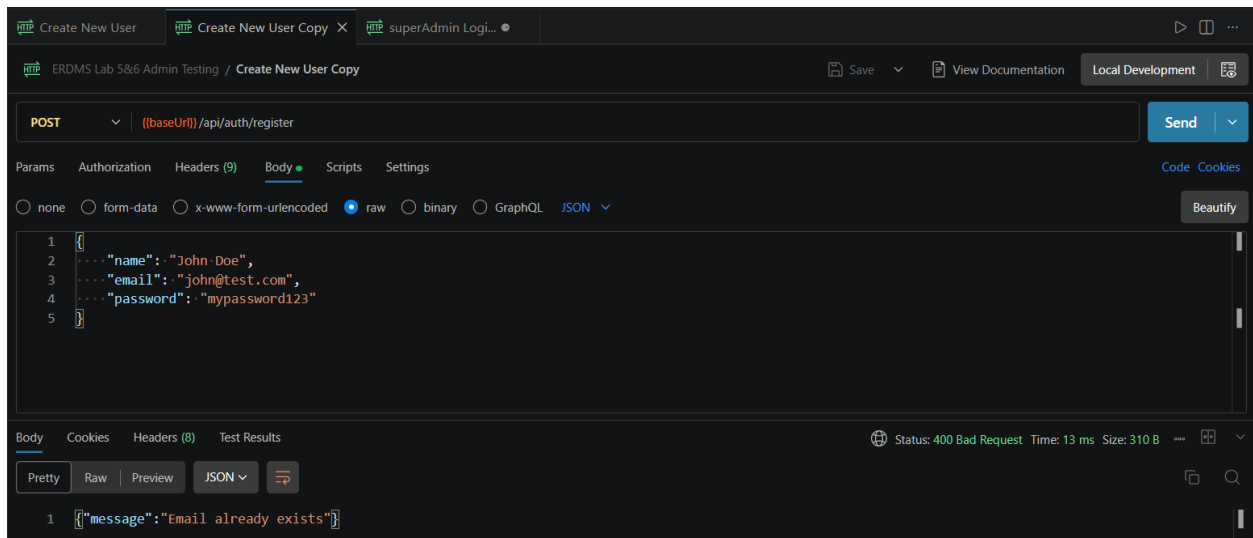
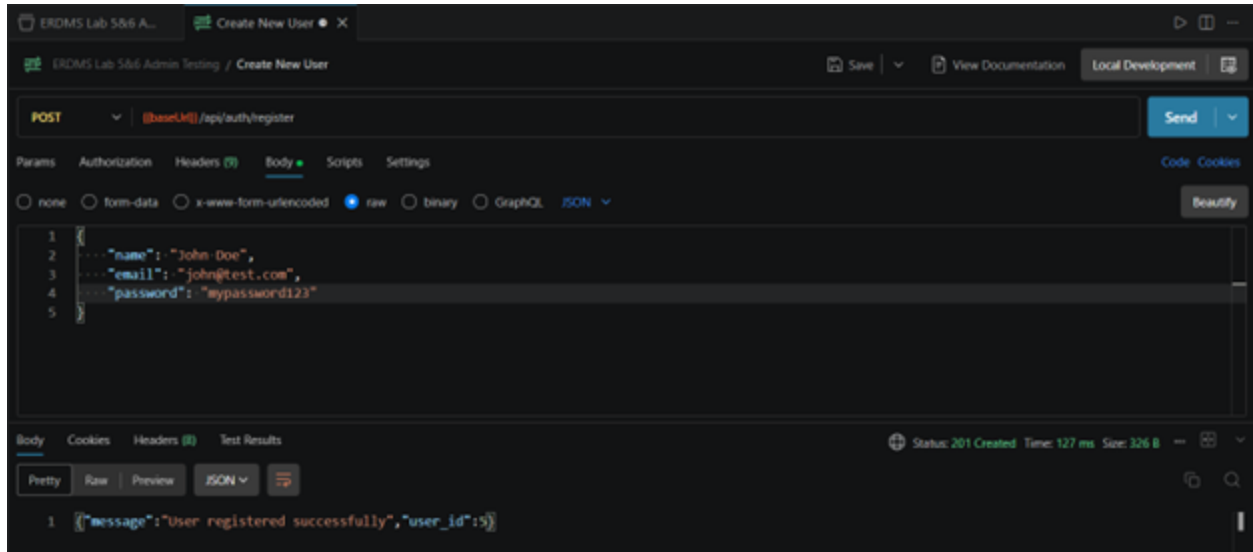
Maghirang, Rhem

Monfero, Andrei Luis

Salvador, Jun Michael

BSCPE 2-B

Register Module:



The image displays three sequential screenshots of a REST client interface, likely Postman, used for testing an API endpoint. Each screenshot shows a POST request to `((baseUrl))/api/auth/login`.

First Screenshot: The request body is a JSON object: `{ "name": "John-Doe", "email": "john@test.com", "password": "mypassword123" }`. The response status is **200 OK**, and the response body is a large JSON object containing a success message, a token, and user details: `{ "message": "Login successful", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjo1LCJ0eW11Ijo1Sm90bIBEB2U1LCJlbWVpbC16ImpvaG5AdGVzdC5jb20iLCJyb2x1X2lkIjoyLCJyb2x1X25hbWUiOiJlbXBsb3llZXMiLCJpYXQiOiJE3Nzk2MjgyNjIsImV4cCI6MTc3OTYzMjg2Mn0.eyJmu2h7VDDdExIoOOWNlUesIbH1Bm8cYs1wQ01XYGm", "user": { "user_id": 5, "name": "John Doe", "email": "john@test.com", "role": "employees", "status": "active" } }`.

Second Screenshot: The request body is a JSON object: `{ "name": "John-Doe", "email": "john@test.com", "password": "wrongpassword123" }`. The response status is **401 Unauthorized**, and the response body is `{ "message": "Invalid email or password" }`.

Third Screenshot: The request body is a JSON object: `{ "name": "John-Doe", "email": "", "password": "mypassword123" }`. The response status is **401 Unauthorized**, and the response body is `{ "message": "Invalid email or password" }`.

Password Hashing:

		user_id	name	email	password	role_id	created_at	status
☐	 Edit  Copy  Delete	1	Test User	test@example.com	\$2b\$10\$Un.0IDK4qmbSQSDYo8xHNePir1v9OTivrs7uZfDl2kJ5...	2	2026-05-20 22:59:31	active
☐	 Edit  Copy  Delete	2	Test User	testing@example.com	\$2b\$10\$3zKKuSMNyeE3l0w5mlrhOrEwFU6G7nwYfLnZ8l1...	2	2026-05-20 23:34:09	active
☐	 Edit  Copy  Delete	3	System Administrator	admin@erds.com	\$2b\$10\$Eev91VFMMgN4V1RXNUTp0AKt3j6cJpCvIS37QBFO...	1	2026-05-21 00:05:32	active
☐	 Edit  Copy  Delete	4	Jun Doe	john@company.com	\$2b\$10\$5k3RDFcox.47.2NUq6u65sg.ELh2cP6t8Yt/uT2tjfnu...	2	2026-05-21 00:18:58	active
☐	 Edit  Copy  Delete	5	John Doe	john@test.com	\$2b\$10\$pVLPrquEX3kwyxhKisuq.dG6rC9TE0g9FUzUmHY1K...	2	2026-05-24 21:07:01	active

Logout Module:

The screenshot displays the REST Client interface with the following details:

- URL:** `{{baseUri}}/api/auth/logout`
- Method:** POST
- Headers:** 9 hidden (expanded to show: authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkjo1LCJuaWY1IjoiSm9obiE2UilCjBWFp...)
- Body:** `{"message": "Logout successful"}`
- Status:** 200 OK
- Time:** 25 ms
- Size:** 298 B

Admin Login:

The screenshot shows the Postman interface with a REST client tab selected. The URL is `{{baseUrl}}/api/auth/login`. The method is **POST**. The body is set to **raw** with JSON format. The JSON payload is:

```
{
  "email": "admin@erdms.com",
  "password": "Admin@123"
}
```

The response status is **200 OK**, time taken is **128 ms**, and size is **681 B**. The response body is displayed in JSON format:

```
{
  "message": "Login successful",
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.\neyjc2VyX2lkijozLCJuYWVmlrjoiU3ZldGVtIEFkbWluaXN0cmFob3IiLCJlbWpbcCI6ImFkbWluQGVyZG1zLmNvbSIsInJvbnVbYwQiOiJEsInJvbnVbYwFTZSI6ImFkbWluIiwiaWF0IjoxNzc5MjI0ODY2LCJleHAiOjE3NzkzMzI0bjZ9.j1glxKV1YAOK0he1IGG76PrnEWESz9oUbM192e_x0",
  "user": {
    "user_id": 3,
    "name": "System Administrator",
    "email": "admin@erdms.com",
    "role": "admin",
    "status": "active"
  }
}
```

Role Based Routes:

Create New UserCreate New User CopyUser Logout ModuleGet All Users (...)

ERDMS Lab 7&8 Admin Testing / Get All Users (Admin only Feature)

SaveView DocumentationLocal Development

GET{{baseUrl}}/api/usersSend

ParamsAuthorizationHeaders (8)BodyScriptsSettingsCodeCookies

Headers7 hidden

	Key	Value
☒	authorization	Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkjo1LCJwYV1lIjo1U3ZldGVhbiEFkbWluaXN0...
	Key	Value

BodyCookiesHeaders (8)Test ResultsStatus: 200 OKTime: 17 msSize: 1.02 KB

PrettyRawPreviewJSON

```
1 [{"user_id":1,"name":"Test User","email":"test@example.com","role_id":2,"role_name":"employees","status":"active","created_at":"2026-05-20T14:59:31.000Z"}, {"user_id":2,"name":"Test User","email":"testing@example.com","role_id":2,"role_name":"employees","status":"active","created_at":"2026-05-20T15:34:09.000Z"}, {"user_id":3,"name":"System Administrator","email":"admin@erdms.com","role_id":1,"role_name":"admin","status":"active","created_at":"2026-05-20T16:05:32.000Z"}, {"user_id":4,"name":"Jun Doe","email":"john@company.com","role_id":2,"role_name":"employees","status":"active","created_at":"2026-05-20T16:18:58.000Z"}, {"user_id":5,"name":"John Doe","email":"john@test.com","role_id":2,"role_name":"employees","status":"active","created_at":"2026-05-24T13:07:01.000Z"}]
```

Create New UserCreate New User CopyUser Logout ModuleGet All Users (...)

ERDMS Lab 7&8 Admin Testing / Get All Users (Admin only Feature)

SaveView DocumentationLocal Development

GET{{baseUrl}}/api/usersSend

ParamsAuthorizationHeaders (8)BodyScriptsSettingsCodeCookies

Headers7 hidden

	Key	Value
☒	authorization	Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkjo1LCJwYV1lIjo1U3ZldGVhbiEFkbWluaXN0...
	Key	Value

BodyCookiesHeaders (8)Test ResultsStatus: 403 ForbiddenTime: 7 msSize: 314 B

PrettyRawPreviewJSON

```
1 [{"message":"Access denied. Admin only."}]
```

Create New UserCreate New User CopyUser Logout ModuleGet All Users (...)

ERDMS Lab 5&6 Admin Testing / Get User Profile

SaveView DocumentationLocal Development

GET{{baseUrl}}/api/users/profile/meSend

ParamsAuthorizationHeaders (8)BodyScriptsSettingsCodeCookies

Headers7 hidden

	Key	Value
☒	authorization	Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkjo1LCJwYV1lIjo1U3ZldGVhbiEFkbWluaXN0...
	Key	Value

BodyCookiesHeaders (8)Test ResultsStatus: 200 OKTime: 7 msSize: 405 B

PrettyRawPreviewJSON

```
1 [{"user_id":5,"name":"John Doe","email":"john@test.com","role_name":"employees","status":"active","created_at":"2026-05-24T13:07:01.000Z"}]
```

These pictures show how the system protects routes based on role permissions. Admins can get all users while normal users cannot. Normal users are restricted to getting their own profile only.

